



Computer science, College of Engineering
Effat University
Saudi Arabia, Jeddah

Governance, Risk & Compliance in Cybersecurity – Final Project Report

CS 3178 - GRC
Final Project - Spring 2026

Instructor: Dr. Sohail Khan

Abeer Hussain	S22107714
Sarah Eid	S22107757
Nancy Elhaddad	S20206871

Contents

1	Executive Summary	2
2	Task 1: Risk Assessment	2
2.1	Risk Register Table	2
2.2	Risk Heat Map	3
2.3	Top 3 Risks	3
2.4	Cisco Assistant Screenshots	4
3	Task 2: Compliance Gap Analysis	5
3.1	GDPR Requirements	5
3.2	PDPL Requirements	6
3.3	Gap Analysis Table	7
3.4	Top 3 Critical Risks	7
3.5	Remediation Recommendations	7
3.6	Cisco Assistant Screenshots	8
4	Task 3: Incident Response Plan	9
4.1	3.1 Preparation	9
4.2	3.2 Detection & Analysis	9
4.3	Containment, eradication and recovery	10
4.4	Post-Incident Review	10
5	Conclusion	11
6	References	11
7	Appendices	11

1 Executive Summary

The purpose of the report was to evaluate Noor Pay's existing cybersecurity and compliance situation, and identify key risks and areas for improvement. The results suggest that NoorPay has numerous material weaknesses, including lack of security governance, risk management, and incident response plans. These gaps present an increased likelihood of future data breaches and the potential for regulatory penalties.

The most significant risks include: unauthorized access to customer financial data; insufficient cloud security measures; and no formal incident response plan. These risks are particularly concerning in light of a previous data breach in which NoorPay experienced the loss of 12,000 customer records without any formal documentation.

From a compliance perspective, NoorPay does not comply with many requirements under the General Data Protection Regulation (GDPR) or the Saudi Personal Data Protection Law (PDPL). The major compliance deficiencies include: no documented security roles; no breach notification procedures; and insufficient documentation of cybersecurity practices.

In order to solve these issues, NoorPay should take three high-priority actions: establish a formal incident response plan; clarify cybersecurity responsibilities; and increase both access controls and cloud security. Furthermore, implementing a formal risk management process will provide leads to the ongoing assessment of risks and ensure that NoorPay maintains compliance with applicable laws and regulations.

The combination of these efforts will assist NoorPay in reducing its exposure to cybersecurity risks, enhancing its compliance with applicable laws and regulations, and improving trust with its customers.

2 Task 1: Risk Assessment

2.1 Risk Register Table

Risk ID	Risk Description	Affected Asset	Threat Source	Likelihood	Impact	Risk Rating	Risk Level
R1	Cloud misconfiguration may expose sensitive customer data	Cloud infrastructure	Human error / attackers	4	5	20	High
R2	Weak access control may allow unauthorized system access	IT systems	Unauthorized users	4	4	16	High
R3	Data breach exposure due to sensitive financial data storage	Customer database	External attackers	4	5	20	High
R4	Absence of a CISO may weaken security governance	Security management process	Internal mismanagement	3	4	12	Medium
R5	Informal risk management may leave risks unidentified	Risk management process	Organizational weakness	3	3	9	Medium
R6	Lack of incident response plan may delay breach response	Incident response process	Security incidents	3	5	15	High
R7	GDPR/PDPL non-compliance may result in legal penalties	Compliance system	Regulatory authorities	3	4	12	Medium
R8	Undocumented past breach may lead to repeated vulnerabilities	Customer data	External attackers	3	4	12	Medium

Table 1: Risk Register showing risk descriptions, scores, and classifications

2.2 Risk Heat Map

Impact ↓ / Likelihood →	1	2	3	4	5
5			R6	R1, R3	
4			R4, R7, R8	R2	
3			R5		
2					
1					

Table 2: Risk Heat Map showing distribution of risks based on likelihood and impact

2.3 Top 3 Risks

1. Data Breach Exposure (R3)

This is the most critical risk because NoorPay processes large amounts of sensitive financial data, such as account details and identity documents. NoorPay already suffered a data breach that resulted in 12,000 records being stolen, so this threat may recur. If there were to be another data breach against NoorPay, they could face financial loss and get GDPR or PDPL penalties.

2. Cloud Misconfiguration (R1)

NoorPay is using a cloud infrastructure and does not have an official cloud security policy. In cases like these, there is a high risk that sensitive customer data could be accessed by unauthorized people. due to a cloud misconfiguration. This risk could impact customer trust.

3. Lack of Incident Response Plan (R6)

Without a good incident response plan, NoorPay may not be able to respond effectively to security incidents. Especially because a previous breach was not formally documented, suggesting weak incident handling practices. Delayed detection and response could significantly increase the impact of future attacks.

2.4 Cisco Assistant Screenshots

Associated risk scenarios

Filters Show 10 entries + Add risk scenario

ID	NAME	THREATS	EXISTING CONTROLS	CURRENT LEVEL	WITHIN TOLERANCE	EXTRA CONTROLS	RESIDUAL LEVEL	
R.01	Cloud Misconfiguration	• Human error / attackers	--	High	--	--	--	
R.02	Weak Access Control	• Unauthorized Access	--	High	--	--	--	
R.03	Data Breach Exposure	• External Attackers	--	High	--	--	--	
R.04	No CISO	• Internal Mismanagement	--	High	--	--	--	
R.05	Weak Risk Management	• Organizational Weakness	--	Medium	--	--	--	
R.06	No Incident Response Plan	• Security Incident	--	High	--	--	--	
R.07	GDPR Non-Compliance	• Regulatory Action	--	High	--	--	--	
R.08	Undocumented Data Breach	• External Attackers	--	High	--	--	--	

Showing 1 to 8 of 8 Previous 1 Next

Screenshot 1: Risk scenarios documented in CISO Assistant showing all identified risks for NoorPay and their current risk levels.

ID

Name

R.01

Cloud Misconfiguration

Edit

Description

Lack of a cloud security policy may lead to misconfigured systems exposing sensitive customer data

Sync to actions

Scope

Domain

NoorPay

GRC

Risk assessment

NoorPay Risk Assessment -

1.0

Version

1.0

Status

Last update

5/1/2026,
12:12:31 AM

Assigned to

abeerahrar@gmail.com

Treatment

decision

Open

Assets

Search...

Show

10

entries

ID	NAME	TYPE	SECURITY TARGETS	DISASTI RECOVER OBJECT
	Cloud infrastructure	Primary	--	--

Showing 1 to 1 of 1

Previous

1

Next

Threats

Search...

Show

10

entries

ID	NAME	DESCRIPTION	LIBRARY	DOM
-	Human error / attackers	Unauthorized access or misconfiguration	-	NoorPay GRC

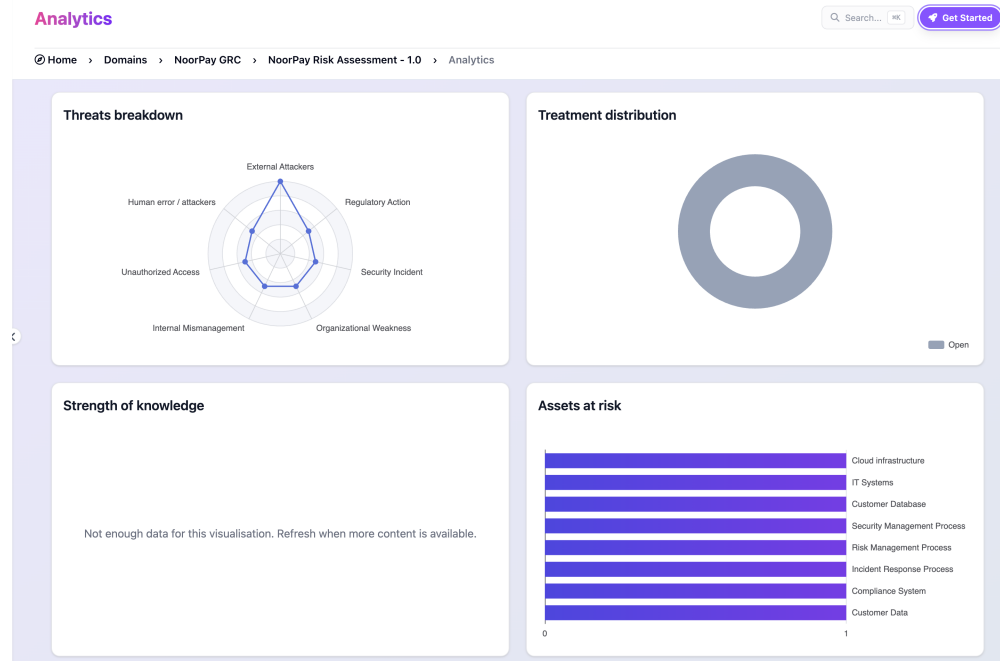
Showing 1 to 1 of 1

Previous

1

Next

Screenshot 2: Detailed view of a risk scenario in CISO Assistant showing risk description, associated assets, and threats.



Screenshot 3: Risk summary dashboard from CISO Assistant showing threats breakdown, assets at risk, and overall risk distribution.

3 Task 2: Compliance Gap Analysis

3.1 GDPR Requirements

1. Principles relating to processing of personal data (Article 5)

Why it applies: NoorPay processes large amounts of personal and financial data, so it needs accountability and proper data protection practices.

Status: Non-compliant, because NoorPay has no formal risk register or documented processes, showing a lack of accountability.

2. Data Protection by Design and by Default (Article 25)

Why it applies: NoorPay uses cloud infrastructure, so systems must be securely designed and configured from the start.

Status: Non-compliant, because NoorPay has no formal cloud security policy, increasing the risk of misconfiguration and data exposure.

3. Security of Processing (Article 32)

Why it applies: NoorPay must protect sensitive customer data through appropriate technical and organizational security measures.

Status: Partially compliant, because some controls exist, but weak access control and lack of formal security policies show incomplete protection.

4. Notification of a Personal Data Breach (Article 33)

Why it applies: NoorPay must report personal data breaches within a required timeframe to authorities.

Status: Non-compliant, because a breach involving 12,000 records was not formally documented or reported.

5. Communication of a Personal Data Breach to the Data Subject (Article 34)

Why it applies: Customers must be informed if their personal data is compromised.

Status: Non-compliant, because there is no evidence that affected users were formally notified after the breach.

6. Designation of a Data Protection Officer (Article 37)

Why it applies: NoorPay processes large-scale sensitive data and should assign responsibility for data protection.

Status: Non-compliant, because NoorPay has no CISO or data protection.

3.2 PDPL Requirements**1. Lawful Basis for Processing Personal Data**

Why it applies: NoorPay processes personal and financial data, so it must ensure data is collected and used lawfully.

Status: Partially compliant, because NoorPay processes data but lacks formal policies to demonstrate lawful processing.

2. Data Security and Protection Measures

Why it applies: NoorPay must protect personal data from unauthorized access or breaches.

Status: Partially compliant, because weak access controls and lack of formal security policies indicate insufficient protection.

3. Data Breach Notification Requirements

Why it applies: Organizations must report personal data breaches to authorities.

Status: Non-compliant, because a previous breach involving 12,000 records was not formally reported or documented.

4. Data Governance and Accountability

Why it applies: NoorPay must have clear policies and responsibilities for managing personal data.

Status: Non-compliant, because there is no formal risk management framework or structured governance.

5. Data Retention and Documentation

Why it applies: Organizations must properly document and manage personal data and incidents.

Status: Non-compliant, because the previous breach was not formally documented.

6. Appointment of Responsible Data Protection Role

Why it applies: Organizations must assign responsibility for data protection and compliance.

Status: Non-compliant, because NoorPay has no dedicated CISO or data protection role.

3.3 Gap Analysis Table

Regulation	Requirement	Current Status	Evidence from Scenario	Gap Description
GDPR	Principles of data processing (Art. 5)	Non-compliant	No formal risk register; informal decisions	Lack of accountability and documentation
GDPR	Data protection by design (Art. 25)	Non-compliant	No cloud security policy	Systems not securely designed/-configured
GDPR	Security of processing (Art. 32)	Partially compliant	Weak access controls	Inadequate technical security measures
GDPR	Breach notification (Art. 33)	Non-compliant	12,000-record breach not documented/reported	No breach reporting process
GDPR	Notify data subjects (Art. 34)	Non-compliant	No evidence users were informed	No customer notification process
GDPR	DPO / governance (Art. 37)	Non-compliant	No CISO or equivalent role	No assigned data protection responsibility
PDPL	Lawful processing of data	Partially compliant	Data processed without formal policies	Lack of documented legal basis
PDPL	Data security measures	Partially compliant	Weak access control	Insufficient protection mechanisms
PDPL	Breach notification	Non-compliant	Previous breach not reported	Missing reporting procedure
PDPL	Data governance	Non-compliant	No structured framework	Poor governance practices
PDPL	Data documentation	Non-compliant	Breach not recorded	Lack of record-keeping
PDPL	Accountability role	Non-compliant	No security leadership	No responsible authority

Table 3: GDPR and PDPL Compliance Gap Analysis Showing Compliance Status, Evidence from the Scenario, and Key Gaps

3.4 Top 3 Critical Risks

1. Absence of a Breach Notification Process

There is no breach notification process, as the company previously had 12,000 customer records that was not reported or documented. This exposes the organization to regulatory penalties under GDPR and PDPL, also a loss of customer trust due to lack of transparency.

2. Lack of Security Governance (No Dedicated CISO)

Having no one dedicated to the security leadership role leads to weak oversight and poor accountability around the protection of data. This increases the risk of making poor security decisions and increases the risk of ongoing non-compliance with applicable regulations and ineffective risk management.

3. No Incident Response Plan

Since the organization does not have an Incident response plan, it will have difficulty detecting, responding to, and recovering from security incidents. This will likely result in operational disruptions, extended periods of time when the systems are down and increased costs due to security incidents occurring in the future.

3.5 Remediation Recommendations

1. Establish a Breach Notification Procedure

Recommendation: Develop and implement a formal breach notification process that includes detection, documentation, and reporting timelines aligned with regulatory requirements.

Priority: Immediate (0–1 month)

Rationale: This is legally required and critical to avoid penalties and improve transparency.

2. Assign a Security Leadership Role

Recommendation: Assign an internal employee to take responsibility for security governance (acting CISO role) and oversee compliance and risk management activities.

Priority: Short-term (1–3 months)

Rationale: Improves accountability and governance without requiring significant additional resources.

3. Develop an Incident Response Plan

Recommendation: Create and document an incident response plan that defines roles, procedures, and communication steps for handling security incidents.

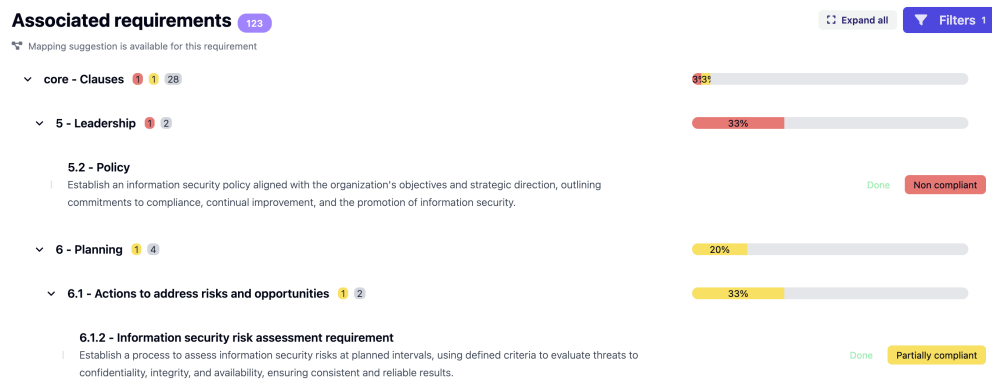
Priority: Immediate (0–1 month)

Rationale: Enables faster response to incidents and reduces operational and financial impact.

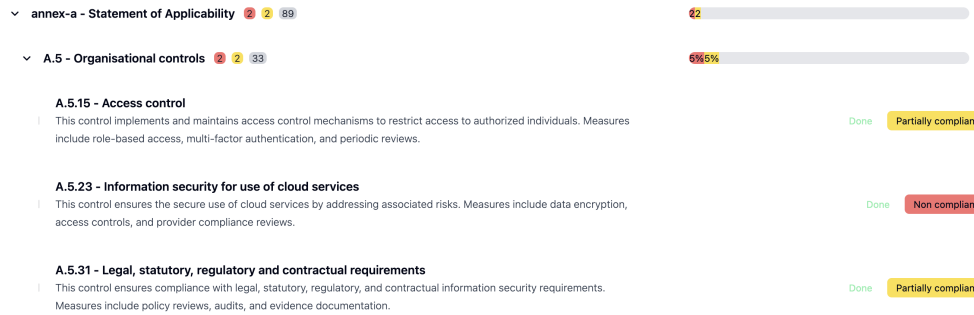
3.6 Cisco Assistant Screenshots



Screenshot 4: Compliance mapping overview showing the selected framework, organizational domain, and overall compliance and progress indicators



Screenshot 5: Compliance mapping view showing selected controls and assigned compliance statuses (Part 1)



Screenshot 6: Compliance mapping view showing additional controls and assigned compliance statuses (Part 2)

4 Task 3: Incident Response Plan

4.1 3.1 Preparation

Incident Response Team Roles

Role	Responsibilities	Escalation Path
IT Manager (Incident Lead)	Leads incident response, coordinates technical actions, makes containment decisions	Escalates to senior management
Compliance Officer	Ensures GDPR & PDPL reporting, handles regulatory communication	Escalates to external regulators
Customer Support Lead	Manages communication with affected customers	Escalates to IT Manager
External Legal Counsel	Provides legal advice on breach obligations and liabilities	Reports to senior management

Table 4: Incident Response Team Roles and Responsibilities

Preparation Measures

- **Log Retention Policy**
Maintain logs for system access and transactions for at least 6–12 months to support investigations.
- **Regulatory Contact List**
Maintain an updated list of contacts for GDPR and PDPL authorities.
- **Incident Response Plan Documentation**
Create and maintain a formal IR plan with defined procedures and responsibilities.
- **Pre-approved Communication Templates**
Prepare templates for notifying customers and regulators in case of a breach.

4.2 3.2 Detection & Analysis

Indicators of Compromise (IoCs)

- **Unusual login activity**
Multiple failed login attempts or logins from unfamiliar locations.

- **Bulk data access/export**
Large volumes of customer financial data accessed at unusual times.
- **Unauthorized privilege escalation**
Accounts gaining higher access rights without approval.

Severity Classification (Triage Table)

Severity	Criteria
Low	No sensitive data affected, minor system anomaly
Medium	Limited access to non-critical data or internal systems
High	Unauthorized access to customer data, but contained
Critical	Large-scale breach involving financial data or active data exfiltration

Table 5: Incident Severity Classification

4.3 Containment, eradication and recovery

During the containment phase, the actions that need to be taken should occur within the first 2 hours of a breach being confirmed. The IT Manager should disable ALL compromised user accounts and isolate systems that have been affected by either completely removing the systems from the network or restricting access to them through Firewall rules. The IT Manager should block all suspicious IP addresses against which the breach occurred, and should also ensure that system logs are preserved for use in the investigation. The IT Manager is to be responsible for carrying out these responsibilities, in addition to escalating the incident to senior management and the Compliance Officer immediately after carrying out these responsibilities in order to ensure a coordinated response.

During the eradication and recovery process, NoorPay must also locate and eliminate any root cause of the breach (fixing system misconfigurations or patching system vulnerabilities). All compromised credentials must be reset, and new security controls (such as stronger authentication mechanisms) must be put in place. All systems that were compromised shall be restored from secure and validated back-ups. Before operations return to normal, the IT Teams shall conduct system scans and will continue with regular monitoring of the systems to ensure that there are no malicious activities or unauthorized accesses remaining.

NoorPay is required by law to notify both the appropriate supervisory authority and affected individuals if they become aware of a data breach within 72 hours under the General Data Protection Regulation (GDPR) as and under the Saudi Personal Data Protection Law (PDPL). Breaches fall under the GDPR obligation to notify the appropriate supervisory authority within 72 hours after becoming aware of them. In addition, all breaches that relate to personal data that has been compromised must be reported to the competent authority without delay; also, individuals whose data has been compromised must be notified of this fact. Not complying with these obligations can result in penalties and/or reputational damage.

4.4 Post-Incident Review

Incident Report Template

- **Incident Description:** Summary of what happened
- **Timeline:** When the incident started, detected, contained, resolved
- **Root Cause:** Technical or human cause of the breach
- **Impact Assessment:** Data affected, systems impacted
- **Lessons Learned:** What failed and what worked

- **Corrective Actions:**

- Action
- Responsible person
- Deadline

Findings from this review should be used to revise NoorPay’s risk register. New risks will be added as needed; existing risks will be reevaluated. This will facilitate ongoing improvements in risk management and help prevent similar incidents from occurring again.

5 Conclusion

The most challenging part of this project was using the CISO Assistant tool effectively and reconciling its output with the requirements from the assignment. The team had trouble navigating through the interaction as well as finding such features as compliance mapping, and ensuring that risks, assets, and controls were entered properly into the system and saved. Given more time and/or resources, the team would like to gain more familiarity with the tool; take more time to explore more advanced features like map controls and risks comprehensively and in detail to provide for a better overall analysis.

6 References

- National Institute of Standards and Technology (NIST). (2012). *Computer Security Incident Handling Guide (SP 800-61 Rev. 2)*.
- European Union. (2016). *General Data Protection Regulation (GDPR)*.
- Saudi Data and Artificial Intelligence Authority (SDAIA). (2021). *Personal Data Protection Law (PDPL)*.
- International Organization for Standardization (ISO). (2022). *ISO/IEC 27001: Information Security Management Systems*.
- CISO Assistant Tool. (2026). *Governance, Risk, and Compliance Platform used for risk assessment and compliance mapping*.

7 Appendices

Appendix A: Risk Assessment Screenshots (CISO Assistant)

Includes risk register and detailed risk scenario views.

Appendix B: Risk Dashboard Overview

Includes dashboard showing threats, assets at risk, and risk distribution.

Appendix C: Compliance Mapping Overview

Includes framework selection and overall compliance status.

Appendix D: Compliance Mapping (Control-Level View)

Includes selected controls and compliance status (Part 1 & Part 2).

Appendix E: Incident Response Tables

Includes incident response roles and severity classification tables.